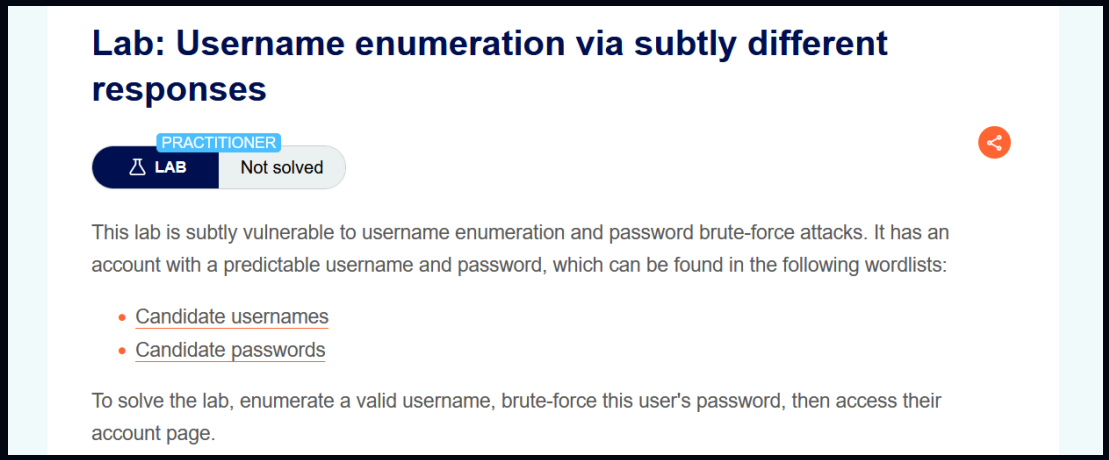
INTRODUCCIÓN AL LABORATORIO

Este documento detalla la resolución técnica del laboratorio **Username enumeration via subtly different responses**. La aplicación es sutilmente vulnerable a la enumeración de nombres de usuario y ataques de fuerza bruta mediante diferencias estructurales o de longitud en las respuestas HTML del servidor.

OBJETIVO DEL EJERCICIO

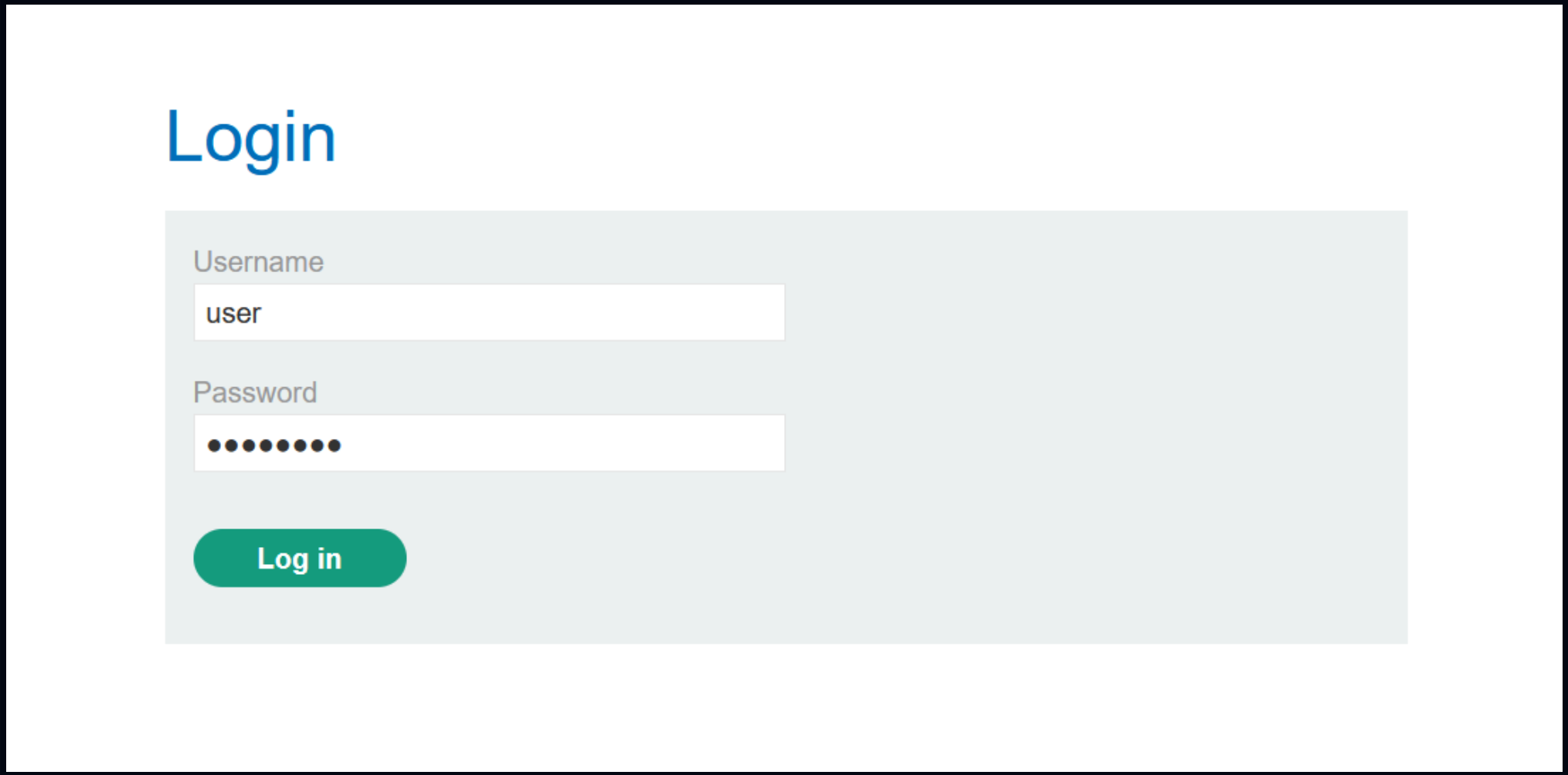
Enumerar un usuario válido usando el módulo *Intruder* y *Grep-Extract*, realizar fuerza bruta sobre la contraseña de dicho usuario para hallar la clave correcta, iniciar sesión e ingresar al panel de la cuenta.

01 Vista general de la plataforma y listas candidatas



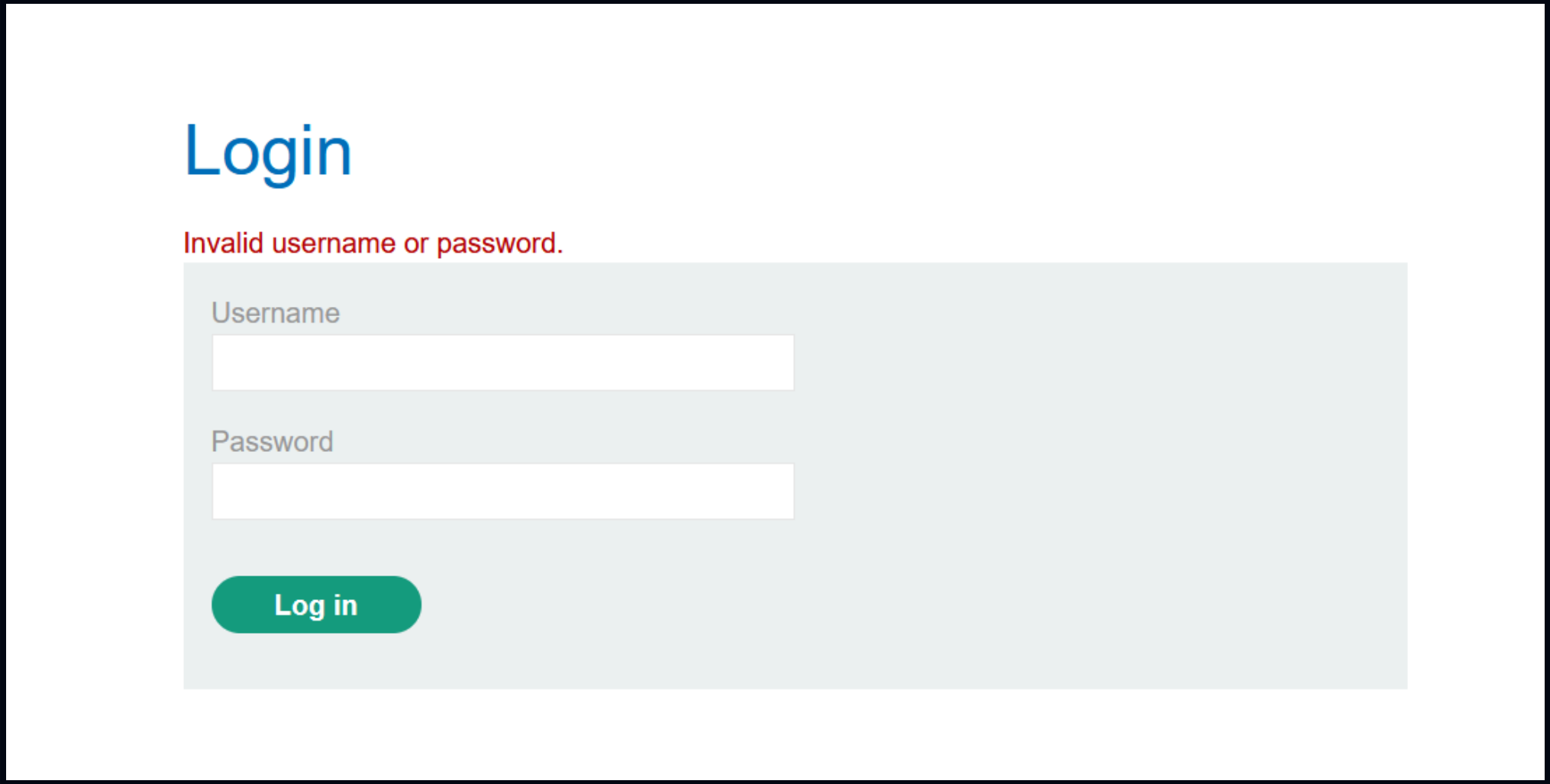
Análisis de la Captura: Revisamos el enunciado oficial en PortSwigger. Se nos proporciona acceso a listas de nombres de usuario y contraseñas candidatas para ejecutar el ataque automatizado.

02 Envío de credenciales de prueba en el endpoint /login



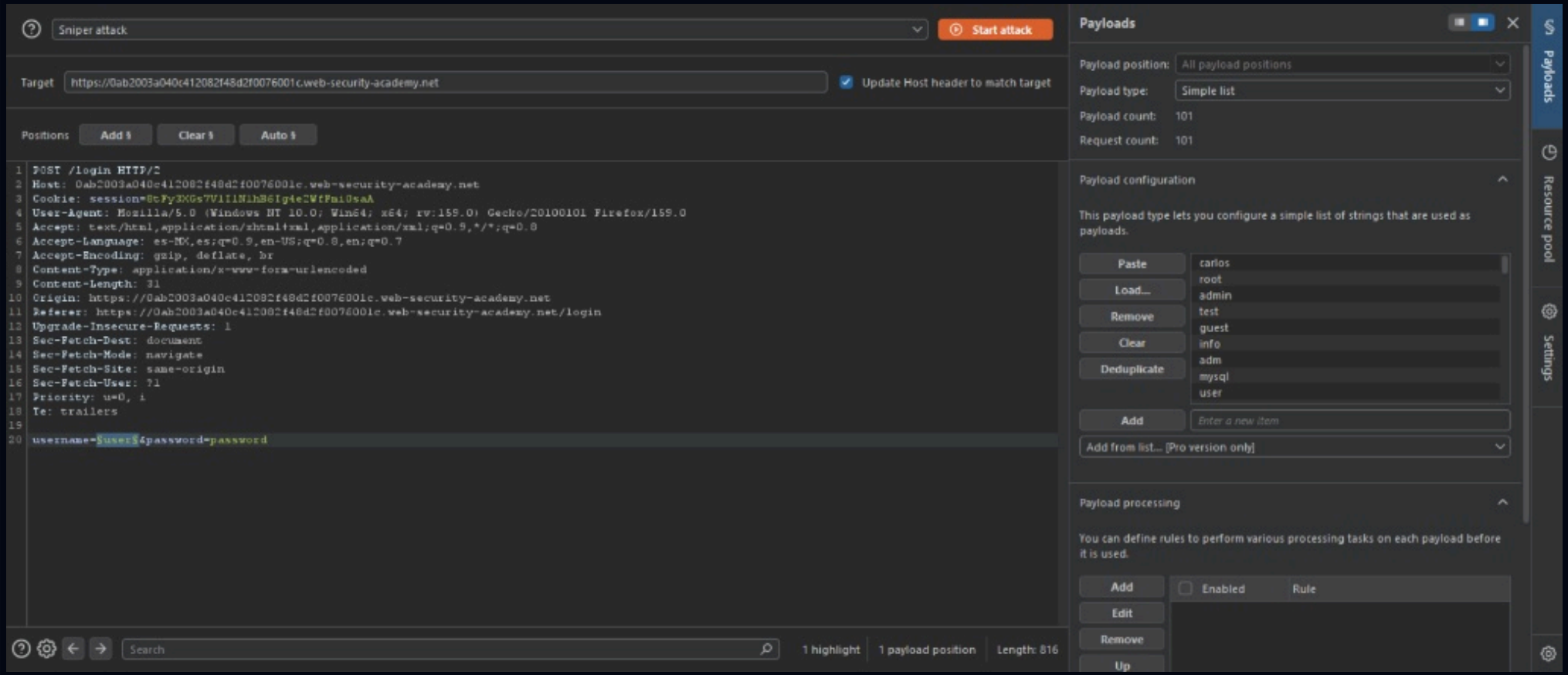
Análisis de la Captura: Introducimos datos de prueba en la interfaz de inicio de sesión para generar la solicitud HTTP que interceptaremos posteriormente con Burp Suite.

03 Visualización del mensaje genérico de error



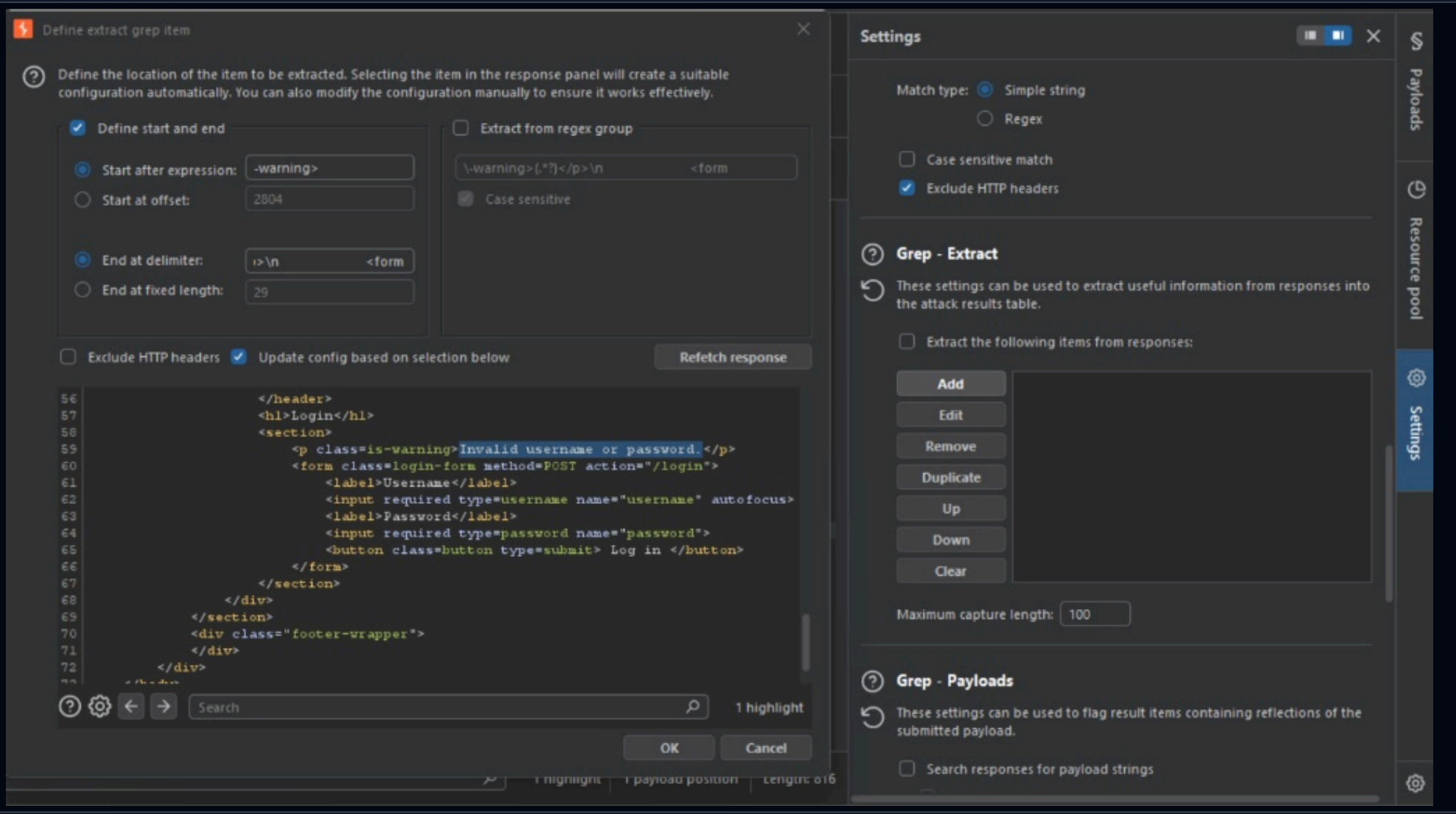
Análisis de la Captura: El servidor responde con el texto estándar `Invalid username or password.` en color rojo, aparentando no revelar si el usuario existe o no a simple vista.

04 Carga de candidatos en el parámetro username



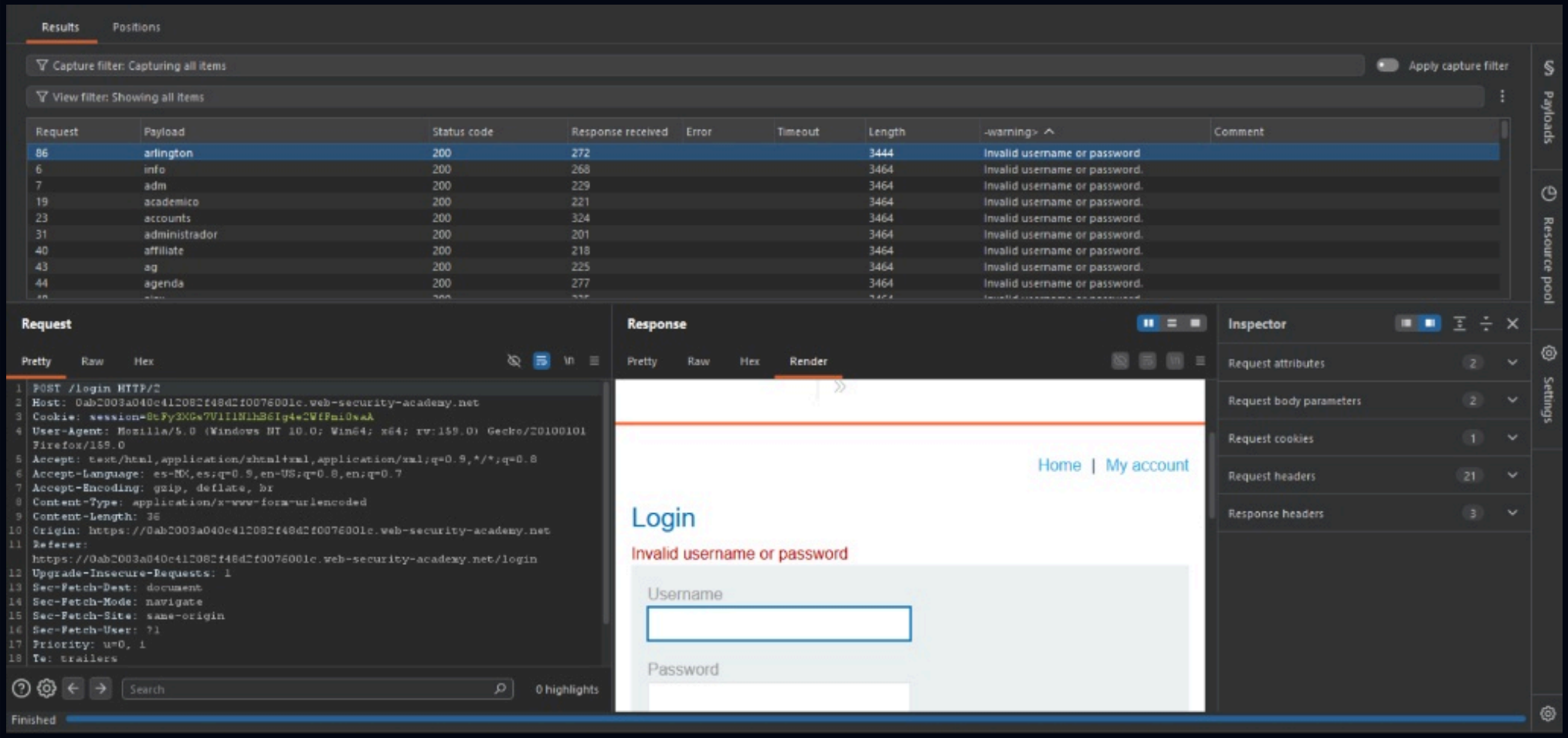
Análisis de la Captura: Enviamos la petición a *Intruder*, seleccionamos ataque Sniper, encerramos el parámetro `username` y cargamos la lista de 101 nombres de usuario candidatos.

05 Extracción de la etiqueta warning en Intruder Settings



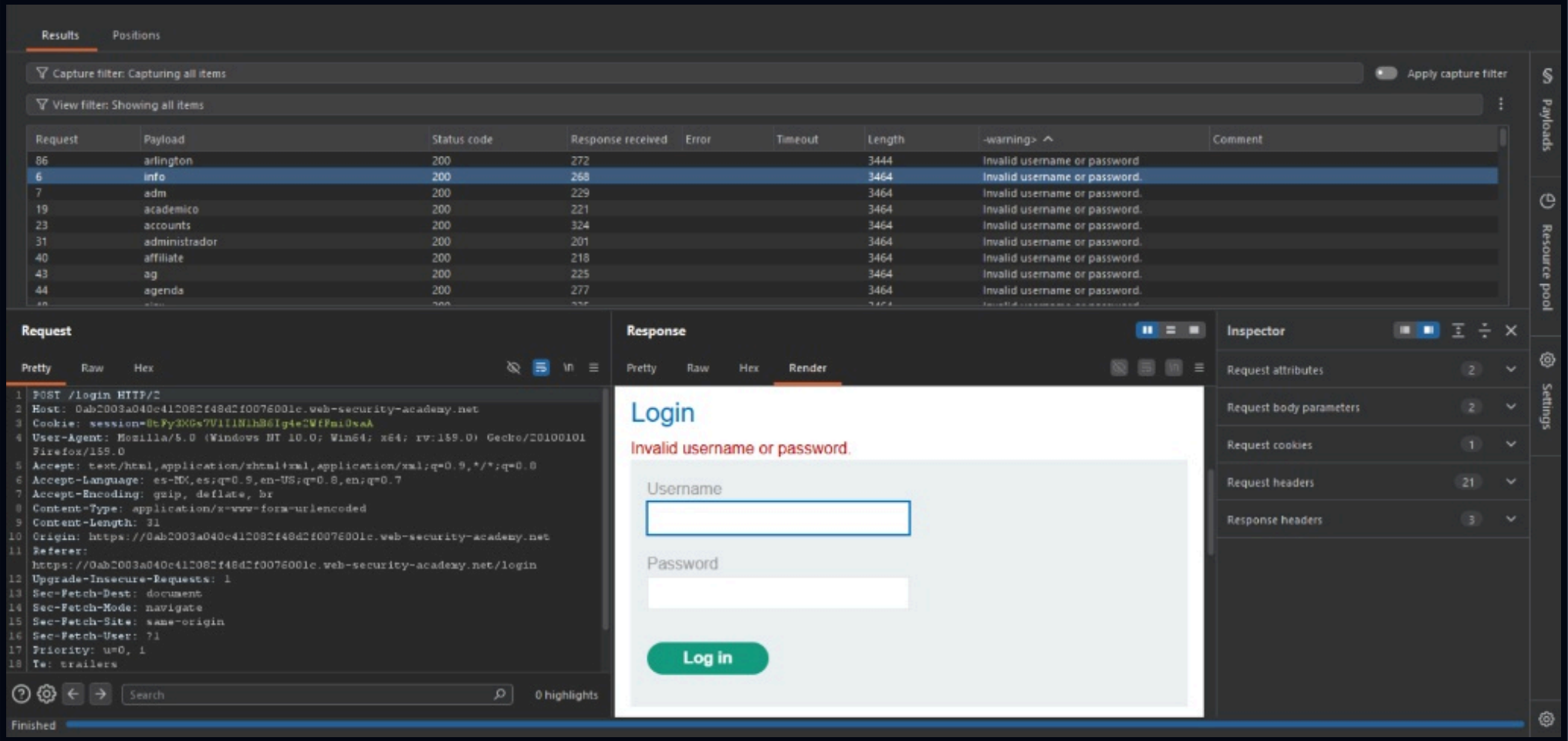
Análisis de la Captura: Como las respuestas visuales son casi idénticas, configuramos *Grep - Extract* en Burp Intruder para aislar el bloque HTML interno `<p class="is-warning">...</p>` y detectar variaciones de longitud.

06 Identificación de longitud atípica (arlington)



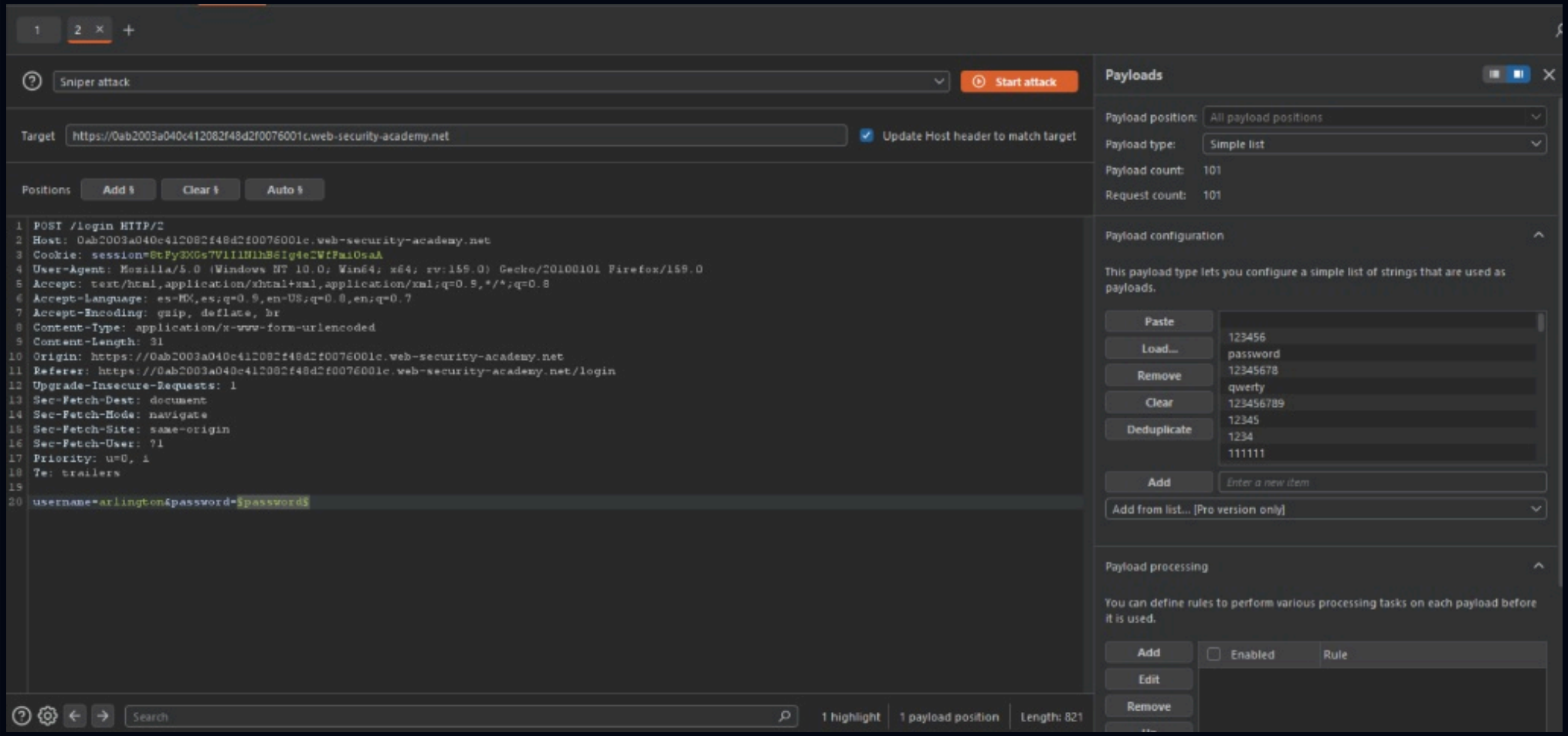
Análisis de la Captura: Al ordenar por longitud (*Length*), el payload `arlington` destaca con 3444 bytes frente a los 3464 del resto, confirmando que se trata de un usuario válido.

07 Comprobación de la respuesta HTTP para arlington



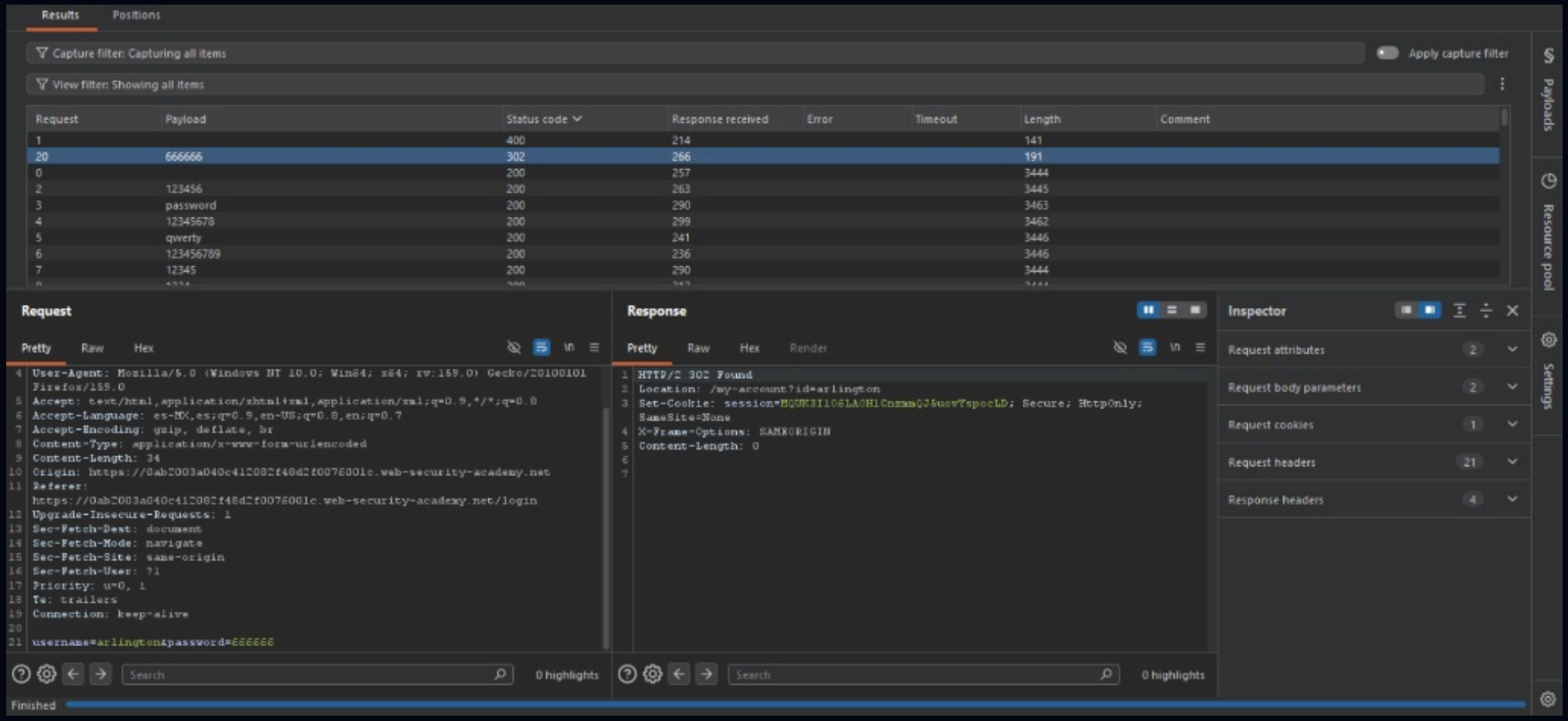
Análisis de la Captura: Inspeccionamos el resultado obtenido para el usuario `arlington`, validando que el servidor procesa sutilmente distinto la estructura interna del HTML devuelto.

08 Fijar username=arlington y probar lista de passwords



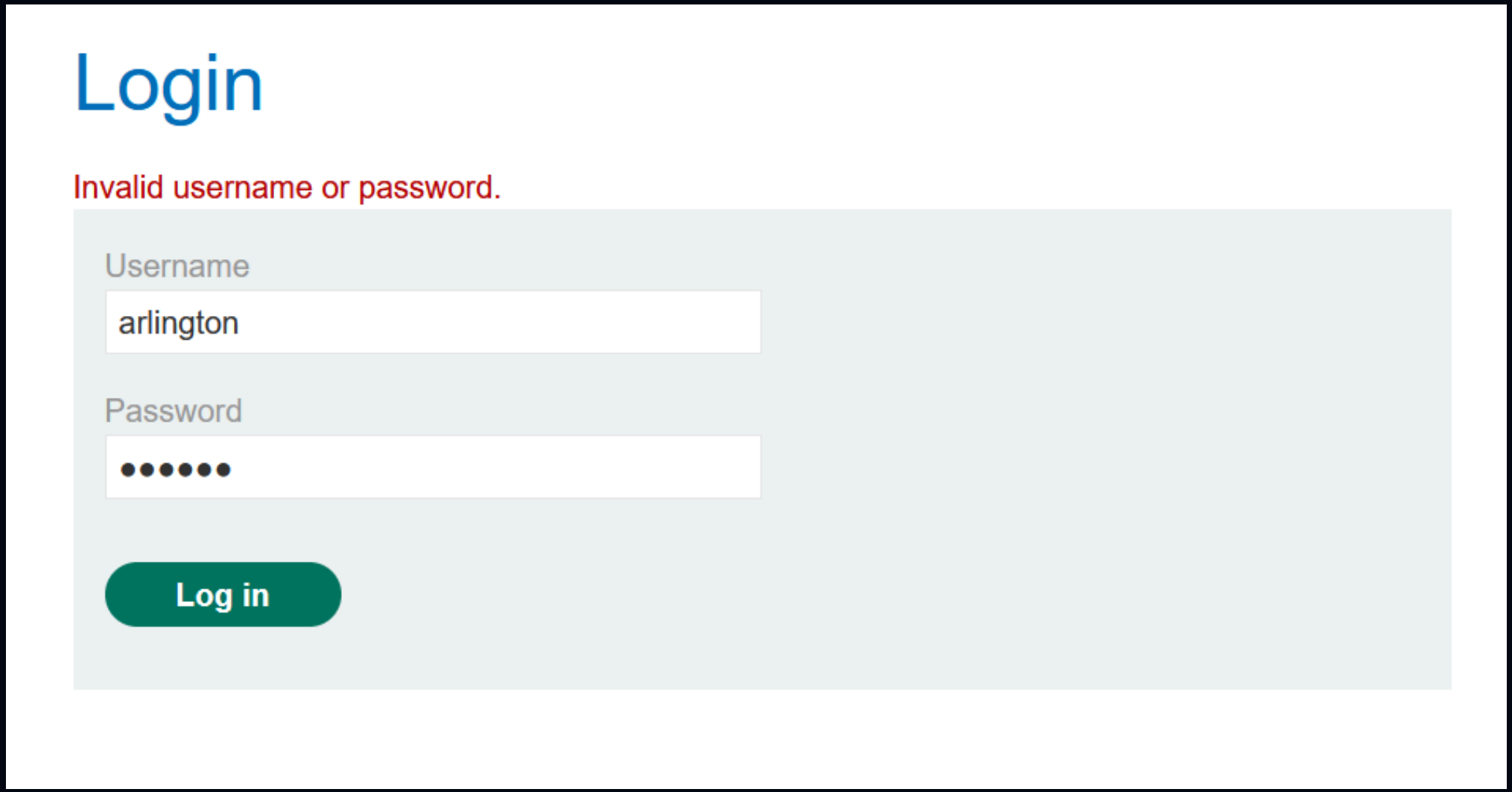
Análisis de la Captura: Con el usuario confirmado, configuramos un nuevo ataque en Intruder fijando `username=arlington` y marcando el parámetro `password` con las 100 contraseñas candidatas.

09 Hallazgo del password correcto (código 302 Found)



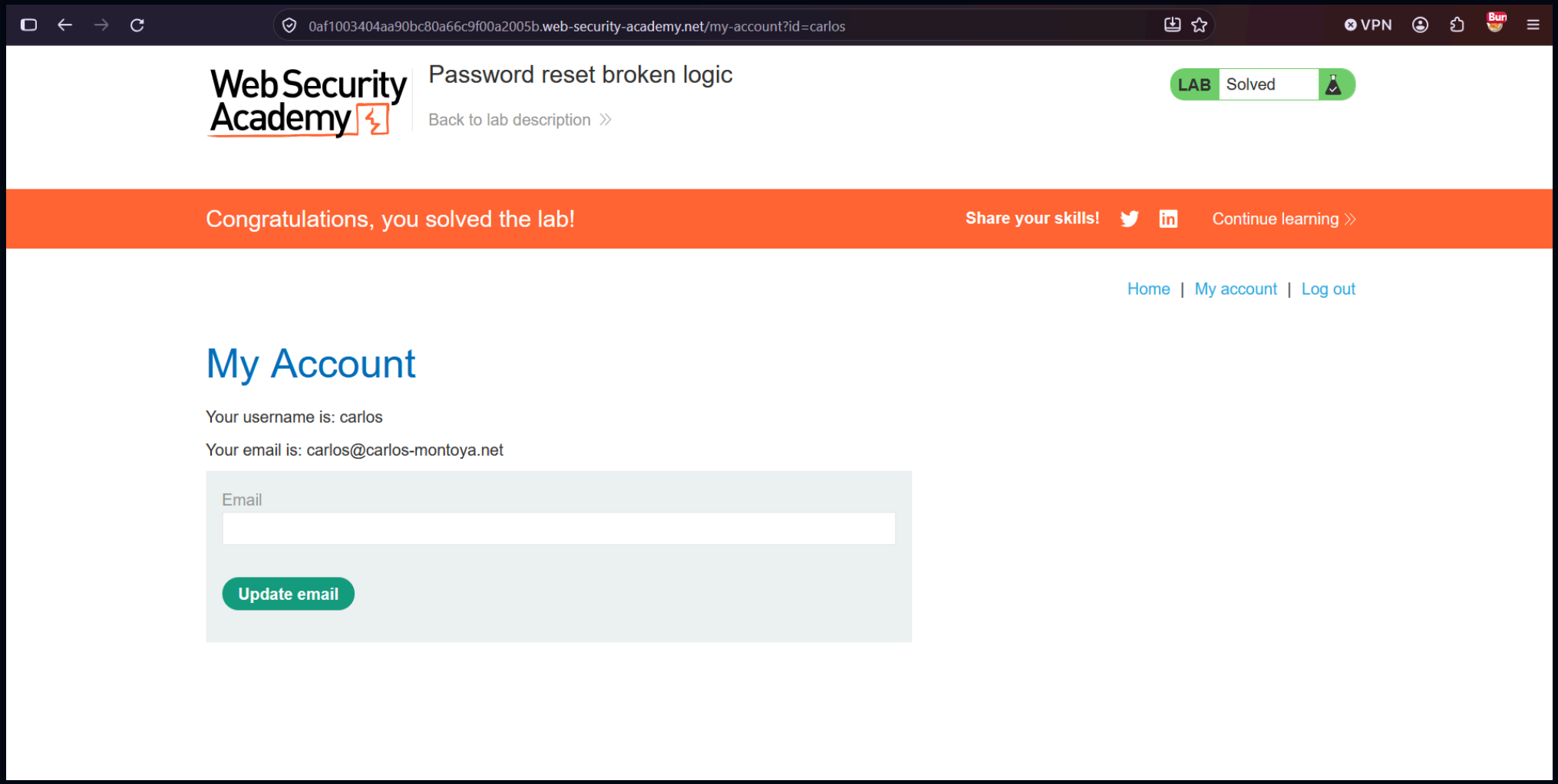
Análisis de la Captura: El ataque de fuerza bruta revela que el payload correcto genera una respuesta `HTTP/2 302 Found` con redirección a `/my-account?id=arlington`.

10 **Login en la interfaz web con arlington / contraseña descubierta**



Análisis de la Captura: Introducimos las credenciales válidas recién obtenidas en el formulario de acceso para autenticarnos en la aplicación web.

11 Acceso a My Account y mensaje de confirmación



Análisis de la Captura: Ingresamos al panel de cuenta del usuario, verificando que la plataforma detecta el laboratorio como superado con el mensaje *Congratulations, you solved the lab!*.

¿POR QUÉ OCURRIÓ ESTA VULNERABILIDAD? (CAUSA RAÍZ)

La vulnerabilidad ocurre debido a una **diferencia sutil en la renderización interna del HTML (Subtle Response Differences / Information Leakage)**:

- Aunque el texto visible del mensaje de error es idéntico (*Invalid username or password*), el motor de plantillas del servidor incluye espacios adicionales, comentarios o varía ligeramente la longitud del DOM cuando el nombre de usuario existe en la base de datos frente a cuando es totalmente inexistente.
- Esto permite a atacantes automatizar análisis estadísticos de longitud de respuesta o extraer sub-etiquetas (Grep-Extract) para filtrar cuentas válidas.

RECOMENDACIONES DE MITIGACIÓN

Normalizar estrictamente las respuestas HTTP de error de autenticación para que devuelvan exactamente la misma estructura y longitud de bytes, combinándolo con mecanismos de limitación de tasa (Rate Limiting) y CAPTCHA.